

(b) Matriz de Evaluación PRAGMATIC Completa para indicadores ISO/IEC 42001 – Ciberseguridad de IA

A continuación se presenta una matriz PRAGMATIC resumida para las principales métricas propuestas. Las valoraciones (0–3) pueden ajustarse según el contexto de cada organización o país; aquí se ofrece una calibración razonable para un entorno nacional como España.

Escala sugerida:

- 0 = Bajo / No cumple.
- 1 = Aceptable.
- 2 = Bueno.
- 3 = Muy bueno.

1. Superficie de exposición y control básico de IA

Métrica M1.1 – Número de sistemas de IA en producción por nivel de riesgo

- Definición: Recuento de sistemas de IA en producción clasificados como alto/medio/bajo riesgo según marco adoptado (p.ej. EU AI Act, marco nacional).

Criterio	Descripción breve	Puntuación sugerida
P – Predictivo	Permite anticipar concentración de riesgo en IA	2
R – Relevante	Directamente vinculada a gestión de riesgos	3
A – Accionable	Ayuda a priorizar recursos de seguridad	3
G – Genuino	Requiere inventario honesto, puede sufrir sesgos	2
M – Significativo	Fácil de entender por dirección	3
P – Preciso	Cálculo sencillo, si hay inventario sólido	2
T – Oportuno	Puede actualizarse trimestralmente	2
I – Independiente	Complementa otras métricas sin redundancia	2
C – Rentable	Coste moderado una vez creado el inventario	2

Métrica M1.2 - Porcentaje de sistemas de IA inventariados

Criterio	Descripción breve	Puntuación
P	Indica capacidad de control futuro	2
R	Clave para cualquier AIMS	3
A	Permite fijar objetivos de cobertura	3
G	Puede inflarse si definiciones son laxas	2
M	Muy comprensible	3
P	Preciso si se definen criterios de inclusión	2
T	Actualizable trimestralmente	2
I	No redundante; base para otros indicadores	2
C	Muy coste-efectivo	3

2. Riesgos y vulnerabilidades específicas de IA

Métrica M2.1 - Número de vulnerabilidades de IA detectadas (por criticidad)

Criterio	Descripción breve	Puntuación
P	Anticipa probabilidad de incidentes	2
R	Directamente ligada a postura de seguridad	3
A	Conduce a planes de remediación	3
G	Depende de la intensidad de pruebas	2
M	Entendible por técnicos y gestores	2
P	Preciso si se usa taxonomía estándar	2
T	Mensual/trimestral es razonable	2
I	Complementa incidentes sin solaparse	2
C	Coste alto si no hay herramientas; medio si ya existen	1

Métrica M2.2 – Tiempo medio de remediación de vulnerabilidades (MTTR-IA)

Criterio	Descripción breve	Puntuación
P	Buen predictor de exposición residual	3
R	Crítico para cualquier sistema de gestión	3
A	Permite fijar SLAs y objetivos de mejora	3
G	Difícil de manipular sin deformar procesos	2
M	Intuitivo para toda la organización	3
P	Preciso si se registra fecha detección/cierre	2
T	Puede seguirse mensualmente	2
I	Independiente de nº total de vulnerabilidades	2
C	Coste bajo si hay sistema de tickets	3

3. Incidentes de seguridad relacionados con IA

Métrica M3.1 – Número de incidentes de IA por tipo

Criterio	Descripción breve	Puntuación
P	Ofrece señales sobre tendencias de amenaza	2
R	Central para cualquier estrategia nacional	3
A	Permite priorizar controles y campañas	3
G	Puede estar infra-reportado	1
M	Muy comprensible	3
P	Preciso si hay tipificación clara	2
T	Actualizable mensualmente	2
I	Se complementa con gravedad y coste	2
C	Coste moderado, requiere disciplina de reporte	2

Métrica M3.2 - Tiempo medio de detección y contención de incidentes de IA (MTTD/MTTC)

Criterio	Descripción breve	Puntuación
P	Altamente predictivo de impacto futuro	3
R	Muy relevante para resiliencia	3
A	Orienta mejoras en SOC/CERT	3
G	Poca tentación de maquillaje si se audita	2
M	Intuitivo (horas/días)	3
P	Preciso con procesos maduros de IR	2
T	Seguimiento mensual/trimestral	2
I	Complementa nº incidentes y gravedad	2
C	Coste bajo con herramientas SIEM/SOAR	3

4. Monitorización continua: deriva, anomalías y abuso

Métrica M4.1 - Porcentaje de modelos con detección de deriva activa

Criterio	Descripción breve	Puntuación
P	Predice riesgo de decisiones degradadas	3
R	Relevante para IA crítica	3
A	Conduce a planes de retraining/revisión	3
G	Depende de honestidad sobre cobertura	2
M	Comprensible para gestión	2
P	Preciso si se define “detección activa”	2
T	Actualizable trimestralmente	2
I	Distinto de métricas de exactitud estática	2
C	Coste medio (requiere infraestructura de monitorización)	1

Métrica M4.2 – Número de anomalías de uso/abuso de IA detectadas y gestionadas

Criterio	Descripción breve	Puntuación
P	Señala patrones emergentes de ataque	3
R	Muy relevante en modelos expuestos a usuarios	3
A	Dispara endurecimiento de controles	3
G	Dependiente de la sensibilidad de detección	2
M	Entendible (“intentos de abuso bloqueados”)	3
P	Preciso si hay reglas y umbrales claros	2
T	Puede medirse semanal/mensualmente	2
I	Complementa incidentes consumados	2
C	Coste medio/alto según nivel de telemetría	1

5. Seguridad de datos para IA

Métrica M5.1 – Porcentaje de datasets de IA clasificados y con control de acceso definido

Criterio	Descripción breve	Puntuación
P	Indica riesgo de exposición de datos	2
R	Directamente vinculado a cumplimiento y ENS	3
A	Permite fijar planes de clasificación	3
G	Puede sobreestimarse si la clasificación es superficial	2
M	Comprensible (“cuántos datasets están bajo control”)	3
P	Preciso con inventario de datos	2
T	Actualizable semestralmente	2
I	Distinto del nº de accesos no autorizados	2
C	Coste medio, alto al inicio, bajo después	2

Métrica M5.2 – Número de accesos no autorizados a datos de IA detectados

Criterio	Descripción breve	Puntuación
P	Indica presión de amenaza interna/externa	2
R	Altamente relevante para seguridad y RGPD	3
A	Conduce a refuerzo de controles	3
G	Depende de calidad del logging	2
M	Muy significativo para dirección	3
P	Preciso si hay correlación de logs adecuada	2
T	Seguimiento mensual	2
I	Complementa incidentes de IA y datos	2
C	Coste medio con SIEM/UEBA	2

6. Terceros y cadena de suministro de IA

Métrica M6.1 – Porcentaje de proveedores de IA evaluados con criterios de seguridad específicos

Criterio	Descripción breve	Puntuación
P	Predice probabilidad de fallos en terceros	2
R	Responsivo a marcos regulatorios (ENS, AI Act)	3
A	Ayuda a priorizar evaluaciones	3
G	Depende de la seriedad de la evaluación	2
M	Entendible para compras y riesgo	3
P	Preciso con registro de proveedores	2
T	Revisable anualmente	2
I	Distinto de nº incidentes de terceros	2
C	Coste bajo una vez que existe proceso	3

Métrica M6.2 – Número de incidentes de seguridad atribuibles a terceros de IA

Criterio	Descripción breve	Puntuación
P	Indica fragilidad de la cadena de suministro	2
R	Muy relevante para servicios críticos	3
A	Conduce a cambios de contrato/proveedor	3
G	Puede ser delicado políticamente	2
M	Muy significativo en foros de riesgo	3
P	Preciso si se recoge origen del incidente	2
T	Seguimiento anual/trimestral	2
I	Complemento de métricas globales de incidentes	2
C	Coste bajo si el proceso de IR ya distingue el origen	3

7. Gobernanza, cultura y capacidad

Métrica M7.1 – Porcentaje de casos de uso de IA con evaluación de impacto (seguridad, ética, cumplimiento)

Criterio	Descripción breve	Puntuación
P	Predice calidad del pipeline de IA	2
R	Conectado a EU AI Act y buenas prácticas	3
A	Permite exigir “no evaluación, no despliegue”	3
G	Depende de rigor de las evaluaciones	2
M	Comprensible para comités de riesgo	3
P	Preciso con registro de casos de uso	2
T	Actualizable semestralmente	2
I	Distinto de métricas puramente técnicas	2
C	Coste medio por el esfuerzo de evaluación	1

Métrica M7.2 – Porcentaje de personal clave con formación anual en seguridad de IA

Criterio	Descripción breve	Puntuación
P	Predice capacidad de respuesta ante amenazas nuevas	2
R	Relevante para resiliencia organizativa	3
A	Permite fijar objetivos de formación	3
G	Fácil de auditar con registros de formación	3
M	Muy comprensible (“quién sabe de qué va esto”)	3
P	Preciso	3
T	Actualizable anualmente	3
I	Independiente de métricas técnicas	2
C	Coste moderado por formación, bajo por medición	2

8. IGM y ROI de IA segura

Métrica M8.1 – Índice Global de Madurez (IGM) en IA segura

Criterio	Descripción breve	Puntuación
P	Sintetiza capacidad futura de gestión	2
R	Relevante para visión estratégica	3
A	Permite fijar metas globales de madurez	3
G	Riesgo de simplificación excesiva	2
M	Muy significativo en reporting ejecutivo	3
P	Preciso si el modelo está bien definido	2
T	Actualización anual/semestral	2
I	Integra múltiples métricas, no independiente	1
C	Coste bajo una vez configurado el modelo	3

Métrica M8.2 – ROI estimado de la gestión de IA segura

Criterio	Descripción breve	Puntuación
P	Permite prever impacto económico de mejoras	2
R	Muy relevante para decisiones de inversión	3
A	Orienta priorización presupuestaria	3
G	Depende de supuestos económicos discutibles	1
M	Potente a nivel de dirección, pero requiere narrativa	2
P	Intrínsecamente aproximado	1
T	Anual/bianual	2
I	Deriva de otras métricas, no totalmente independiente	1
C	Coste medio/alto por modelización	1